# Plano de Gerenciamento de Riscos

**Projeto:** Smart Ace – Grupo Enrolados

**Membros:**
Guilherme Barioni
Iury Xavier
Lilian Conde
Marcus Duque
Murilo Vieira

**Data:** 19/09/2026

**Versão:** 1.0

## 1. Introdução

Este relatório documenta vulnerabilidades confirmadas ou potenciais identificadas na arquitetura e no código do protótipo Smart Ace. A análise considera o fluxo discutido para o projeto: sensores instalados na raquete alimentam o ESP32; o ESP32 realiza aquisição, filtragem, detecção de impacto e classificação dos golpes; os dados são enviados por Bluetooth ao aplicativo/sistema; o aplicativo oferece feedback, gamificação, pontuação e histórico. O subsistema de câmeras permanece externo ao circuito da raquete.

O objetivo deste documento é documentar as possiveis falhas de segurança dos sistemas envolvidos no projeto, buscando aumentar a segurança e garantir a viabilidade do projeto.

## 2. Metodologia

A análise considera os principais componentes atualmente envolvidos no Smart Ace:

- Arquitetura geral do sistema;
- ESP32 e seu firmware;
- MPU6050 e aquisição dos dados de movimento;
- Detecção de impacto;
- Comunicação sem fio entre o dispositivo e o sistema;
- Aplicativo Android;
- Banco de dados local utilizando Room;
- Armazenamento de sessão utilizando SharedPreferences;

- Sistema de gamificação e pontuação;
- Dados provenientes do sistema de câmeras;
- Práticas de desenvolvimento seguro.

Como referência de segurança para o aplicativo móvel, foi utilizado o OWASP Mobile Application Security Verification Standard (MASVS), que organiza controles relacionados a armazenamento, criptografia, autenticação, rede, plataforma, código, resiliência e privacidade.

Também foram considerados riscos recorrentes em sistemas IoT, especialmente aqueles relacionados à comunicação sem fio, credenciais, autenticação de dispositivos, integridade dos dados, firmware e atualização do dispositivo.

A análise foi adaptada ao estágio atual do projeto, evitando considerar como implementados recursos que ainda fazem parte do planejamento.

## 3. Escopo técnico analisado

| Componente | Função | Principais ativos |
|---|---|---|
| ESP32 | Aquisição/processamento | Firmware, configurações e dados dos sensores |
| MPU6050 | Acelerômetro + giroscópio | Dados de movimento |
| Sensor de impacto | Detecção de impacto | Eventos de impacto |
| Bluetooth | Transmissão dos dados do dispositivo | Dados de golpes e comandos |
| Aplicativo Android | Login, feedback, gamificação | Conta, pontuação, histórico |
| Room/SQLite | Persistência local | Usuários e dados associados |
| SharedPreferences | Estado/sessão local | ID do usuário |
| Câmeras | Velocidade, spin e trajetória | Dados da partida |

## 4. Registro de vulnerabilidades

### V01 — Armazenamento potencial de senha sem proteção adequada

**Severidade:** Alta **Status:** Potencial — confirmar no código do Room

**Descrição/evidência:** O modelo de dados discutido contém o campo de senha. Se a senha for persistida em texto puro ou com hash inadequado, uma cópia do banco poderá expor credenciais.

**Correção recomendada:** Armazenar apenas hash forte e apropriado para senhas, com salt; nunca armazenar senha em texto puro. Separar credenciais de outros dados quando possível.

**Referência:** OWASP MASVS-STORAGE / MASVS-CRYPTO

## V02 — Confiança excessiva no ID armazenado em SharedPreferences

**Severidade:** Alta **Status:** Potencial — depende do uso posterior

**Descrição/evidência:** O aplicativo salva o ID do usuário em SharedPreferences e o utiliza para recuperar o usuário. O ID deve representar estado local, não uma prova suficiente de autorização para operações sensíveis.

**Correção recomendada:** Usar sessão/token autenticado para autorização; validar a identidade no backend quando houver serviço remoto; nunca confiar apenas em um identificador local para ações privilegiadas.

**Referência:** OWASP MASVS-AUTH / MASWE-0018

## V03 — Comunicação sem fio sem segurança definida

**Severidade:** Alta **Status:** Em definição

**Descrição/evidência:** O ESP32 precisa transmitir dados do dispositivo para o restante do sistema, mas a especificação disponível não define ainda um protocolo autenticado e criptografado entre raquete e aplicativo/sistema.

**Correção recomendada:** Definir protocolo de comunicação com autenticação dos dispositivos e proteção de confidencialidade/integridade. Usar mecanismo criptográfico autenticado e gerenciamento seguro de chaves.

**Referência:** OWASP MASVS-NETWORK / MASWE-0026

## V04 — Ausência de autenticação/autorização definida para o dispositivo

**Severidade:** Alta **Status:** A verificar

**Descrição/evidência:** Ainda não foi definida uma identidade criptográfica do ESP32 nem uma política para impedir que outro dispositivo envie comandos ou dados falsos.

**Correção recomendada:** Registrar cada dispositivo, autenticar a comunicação e autorizar operações por dispositivo/usuário. Rejeitar mensagens sem autenticação válida.

**Referência:** OWASP MASVS-AUTH / IoT

## V05 — Manipulação de dados de sensores sem validação de origem

**Severidade:** Média **Status:** Potencial

**Descrição/evidência:** Dados de aceleração, rotação e impacto podem influenciar classificação, pontuação e gamificação. Se a mensagem puder ser forjada, pontuação e histórico podem ser manipulados.

**Correção recomendada:** Validar formato, limites, sequência temporal e autenticidade das mensagens; associar eventos a uma sessão/dispositivo autenticado.

**Referência:** MASVS-NETWORK / MASVS-AUTH

## V06 — Atualização segura do firmware não definida

**Severidade:** Média **Status:** A verificar

**Descrição/evidência:** Não há, no escopo atual, mecanismo definido para verificar autenticidade e integridade de novas versões do firmware.

**Correção recomendada:** Adotar atualização assinada/verificada, impedir downgrade indevido e registrar a versão instalada.

**Referência:** OWASP IoT Top 10

### V07 — Logs podem expor dados sensíveis durante depuração

**Severidade:** Média **Status:** A verificar

**Descrição/evidência:** O firmware e o aplicativo podem usar Serial/Log para depuração. Dados de autenticação, tokens ou informações pessoais não devem ser registrados.

**Correção recomendada:** Remover segredos dos logs, usar níveis de log e desabilitar logs sensíveis em builds de produção.

**Referência:** OWASP MASVS-STORAGE / MASVS-CODE

### V08 — Validação de entrada insuficiente no aplicativo

**Severidade:** Média **Status:** A verificar

**Descrição/evidência:** Campos como e-mail e senha precisam ser validados antes de consultas e operações.
Mesmo usando Room, entradas devem ser tratadas como não confiáveis.

**Correção recomendada:** Aplicar validação de formato/tamanho e usar APIs parametrizadas. Manter validação também no servidor caso exista backend.

**Referência:** OWASP MASVS-CODE

### V09 — Componentes Android expostos sem necessidade

**Severidade:** Média **Status:** A verificar

**Descrição/evidência:** Activities, Services, Receivers ou Providers que não precisam ser acessíveis por outros aplicativos devem permanecer protegidos.

**Correção recomendada:** Revisar exported=true/false, permissões e intents; proteger componentes que executam operações sensíveis.

**Referência:** OWASP MASWE-0018

## 5. Matriz de prioridade

| ID | Severidade | Probabilidade atual | Prioridade | Ação |
|---|---|---|---|---|
| V01 | Alta | Média | Alta | Verificar armazenamento da senha e corrigir |
| V02 | Alta | Média | Alta | Não usar ID local como autorização |
| V03 | Alta | Alta | Crítica | Definir comunicação autenticada e criptografada |
| V04 | Alta | Média | Alta | Implementar identidade/autenticação do dispositivo |
| V05 | Média | Média | Média | Validar autenticidade e integridade dos eventos |

| | | | | |
|---|---|---|---|---|
| V06 | Média | Baixa | Média | Planejar atualização segura |
| V07 | Média | Média | Média | Revisar logs |
| V08 | Média | Média | Média | Revisar validação de entrada |
| V09 | Média | Baixa | Baixa/Média | Revisar manifest e componentes |

## 6. Testes de segurança propostos

- Autenticação: testar login com usuário inexistente, senha incorreta, campos vazios e repetição de tentativas.
- Sessão: apagar/alterar o ID salvo localmente e verificar se o aplicativo indevidamente concede acesso.
- Banco local: verificar se senhas, tokens ou outros segredos ficam armazenados em texto puro.
- Rede: capturar o tráfego do protótipo e confirmar se dados sensíveis trafegam sem criptografia ou autenticação.
- ESP32: verificar se um dispositivo não autorizado consegue conectar e enviar eventos falsos.
- Firmware: procurar senhas, chaves e tokens embutidos no código/firmware.
- Integridade: modificar valores de aceleração/rotação enviados e verificar se a aplicação aceita eventosimpossíveis.
- Android: revisar AndroidManifest.xml e componentes exportados.
- Logs: executar o aplicativo/firmware em modo de depuração e procurar credenciais, tokens ou PII.
- Atualização: verificar se existe validação de autenticidade/integridade antes de aceitar firmware novo.

## 7. Plano de segurança aplicado

**Antes da integração final:** corrigir armazenamento de credenciais, definir autenticação do dispositivo, especificar protocolo seguro de comunicação e revisar componentes Android.

**Durante a implementação:** manter validação de entradas, logs sem segredos, separação entre ambiente de testes e produção e controle de versões do firmware.

**Antes da apresentação/entrega:** executar os testes descritos, registrar evidências, marcar cada vulnerabilidade como corrigida, aceita ou pendente e anexar o código-fonte da versão avaliada.

## 8. Conclusão

A análise mostra que a principal superfície de segurança do Smart Ace está na integração entre o dispositivo IoT, a comunicação sem fio e o aplicativo Android. O protótipo já possui uma separação clara entre aquisição de sensores, processamento e aplicação, mas alguns controles ainda precisam ser especificados ou implementados para que a solução possa ser considerada segura. Os pontos prioritários são proteger credenciais, não confiar apenas em identificadores locais, autenticar os

dispositivos e proteger os dados em trânsito. As vulnerabilidades classificadas como 'a verificar' não devem ser apresentadas como falhas confirmadas sem o teste correspondente; elas são itens de auditoria que fazem parte do processo de segurança.

## 9. Referências


- OWASP Mobile Application Security Verification Standard (MASVS): https://mas.owasp.org/MASVS/
- OWASP MASVS — Storage: https://mas.owasp.org/MASVS/05-MASVS-STORAGE/
- OWASP MASVS — Network: https://mas.owasp.org/MASVS/08-MASVS-NETWORK/
- OWASP MASWE-0026 — Network Traffic Not Encrypted: https://mas.owasp.org/MASWE/MASVS-NETWORK/MASWE-0026/
- OWASP MASWE-0018 — Lack of Authentication or Authorization on App Components:https://mas.owasp.org/MASWE/MASVS-AUTH/MASWE-0018/

**OWASP IoT Top 10 (referência histórica de riscos de IoT): https://wiki.owasp.org/images/1/1c/OWASP-IoT-Top-10-2018-final.pdf**